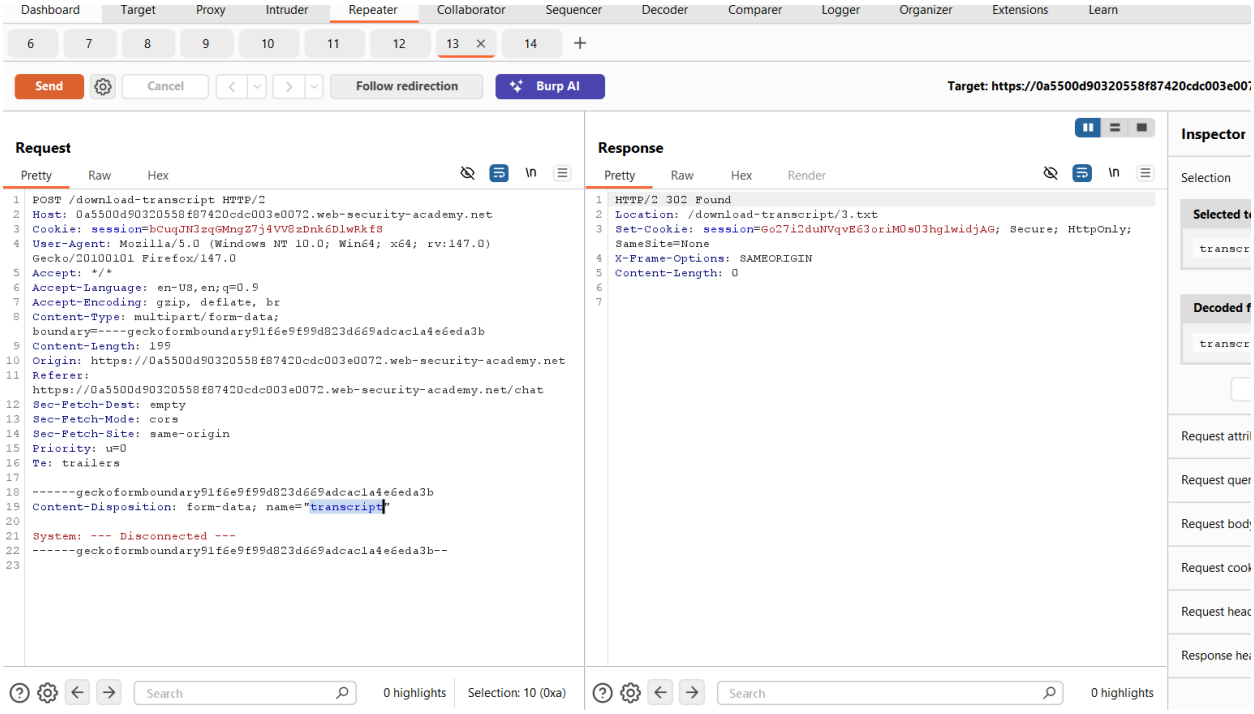
Title: Insecure Direct Object Reference (IDOR) - Unauthorized Access to Chat Transcripts Leading to Credential Disclosure

Access control enforces policy such that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification or destruction of all data, or performing a business function outside the user's limits.

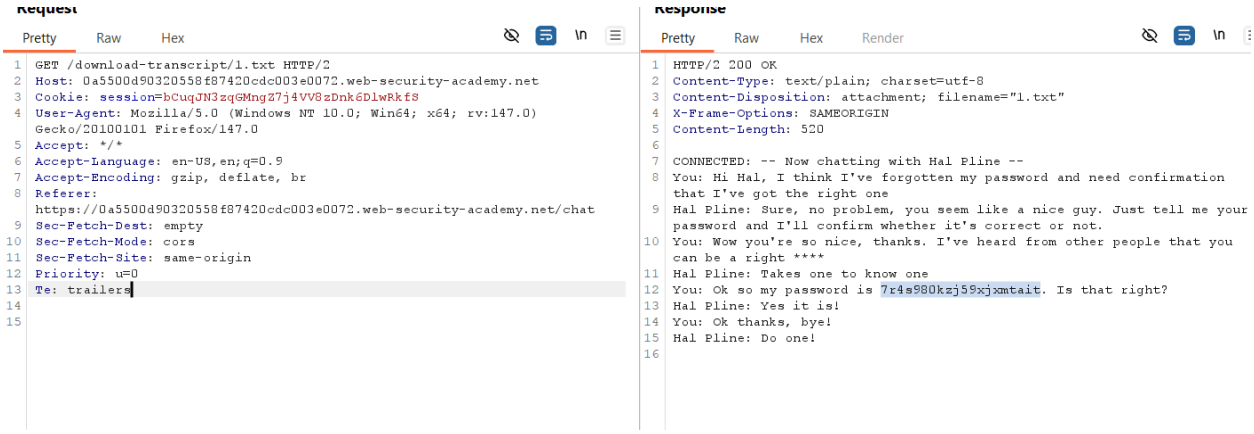
Reproduction Steps:

1.visit https://0a21002f0326821980af0d3500e300da.web-security-academy.net/

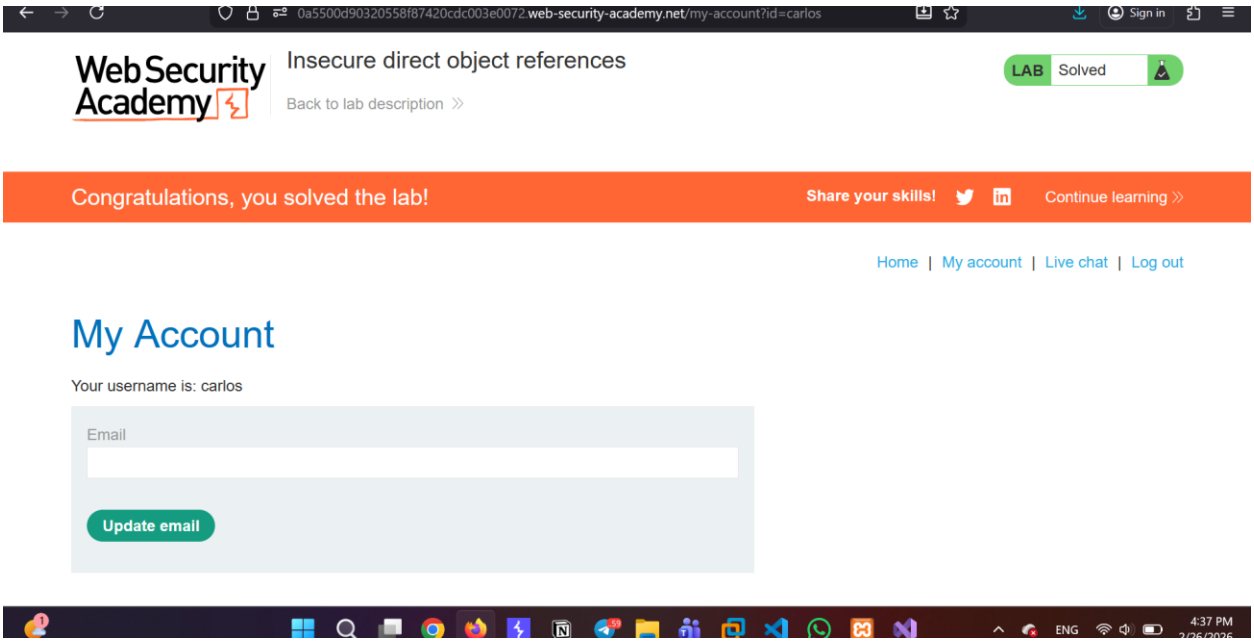
2.go to live chat and send messages and in the end inspect the view transcript



3.the another responded make it to download the file change the number of the txt into1.txt to show the password



4.now enter the username and password (carlos, 7r4s980kzj59xjxmtait)



Impact Statement:

Successful exploitation of this Insecure Direct Object Reference (IDOR) vulnerability allows an unauthenticated or authenticated attacker to enumerate and access other users' private chat transcripts by manipulating the incrementing filename parameter in the transcript URL. By simply changing the filename to a predictable value such as `1.txt`, the attacker is able to retrieve sensitive chat transcripts belonging to other users, which in this case contained plaintext credentials allowing full account takeover.

This vulnerability poses a **Critical** risk to the organization as it exposes private user communications and sensitive data such as passwords to any attacker capable of manipulating a simple URL parameter. The predictable and sequential nature of the transcript filenames makes large-scale enumeration trivial, potentially exposing all stored chat transcripts across all users.

Furthermore, this level of access severely impacts all three pillars of the CIA Triad:

- **Confidentiality:** Private chat transcripts belonging to all users are fully exposed to unauthorized parties, resulting in complete loss of communication confidentiality and potential disclosure of sensitive information such as credentials, PII, and other private data.
- **Integrity:** With stolen credentials obtained from the exposed transcripts, the attacker can log in as the victim user and modify or manipulate their account data and associated records.
- **Availability:** Depending on the privilege level of the compromised account, the attacker may disrupt application services or perform destructive actions against user data.

The disclosure of plaintext credentials within chat transcripts further compounds the severity of this vulnerability, as it enables immediate account takeover without requiring any additional exploitation steps. This may further enable **lateral movement** across the application if the stolen credentials are reused across multiple accounts or systems. This vulnerability may also result in significant **regulatory and legal consequences** under data protection frameworks such as GDPR, as unauthorized access to private user communications and credential disclosure constitutes a serious and reportable data breach.

Mitigation:

To remediate this IDOR vulnerability, it is strongly recommended to implement **server-side authorization checks** on all transcript access requests, ensuring that the requesting user is only permitted to access transcripts associated with their own account. The server must validate the ownership of the requested resource before serving any transcript file, regardless of the filename supplied in the request.

Replace **predictable and sequential filenames** with cryptographically random and unguessable identifiers such as UUIDs for all transcript files. This eliminates the ability to enumerate transcripts through simple filename manipulation, significantly raising the bar for exploitation.

Ensure that **sensitive information such as passwords is never transmitted or stored within chat transcripts** or any other user-accessible logs. Credentials and other sensitive data must be handled exclusively through secure and dedicated authentication channels.

Implement **access control at the file serving layer**, ensuring that transcript files are never directly accessible via static URLs without proper session-based authorization validation. Direct file access should be mediated through application logic that enforces ownership verification.

Conduct regular **access control audits and penetration testing** specifically targeting IDOR vulnerabilities across all resource access endpoints to identify and remediate any instances of missing or improperly enforced authorization checks.

Finally, implement comprehensive **logging and alerting** on all transcript access attempts, enabling the security team to detect and respond to enumeration attempts and unauthorized access in a timely manner.